CYS 410: SECURITY AND RISK MANAGEMENT PRACTICES

MS. NANYANGWE L.R

nanyangweleah@gmail.com

0967203891 (WHATSAPP)

8. INSTITUTIONAL SECURITY MANAGEMENT

- Institutional security management focuses on the security needs of an organization, assessing risks, managing insider threats, and fostering a security-aware culture.
- This area integrates both physical and cyber aspects of security, addressing vulnerabilities within the institution and ensuring that employees, systems, and processes remain secure.
  - Institutional risk assessment
  - Insider threats and mitigation strategies
  - Security awareness training

INSTITUTIONAL RISK ASSESSMENT

- Risk assessment within an institution involves identifying, analysing, and evaluating risks to organizational assets and operations, followed by the implementation of strategies to mitigate these risks.

WHAT IS RISK ASSESSMENT

- The process of identifying potential risks to an institution's operations, evaluating the likelihood of their occurrence, and determining the severity of their impact.
  - It involves assessing both external and internal threats to the organization.
- Its objective is to safeguard physical, financial, intellectual, and human resources, ensuring business continuity and legal compliance.

STEPS TAKEN IN ASSESSING RISK IN AN INSTITUTION

1. **Risk Identification**: Identifying potential threats, including cyber threats, physical security threats, and operational risks (e.g., Disruptions of the Zambian toll gate systems operations).

2. **Risk Evaluation**: Analysing the likelihood and potential impact of identified risks.

    - This may involve using risk matrices or qualitative and quantitative techniques.

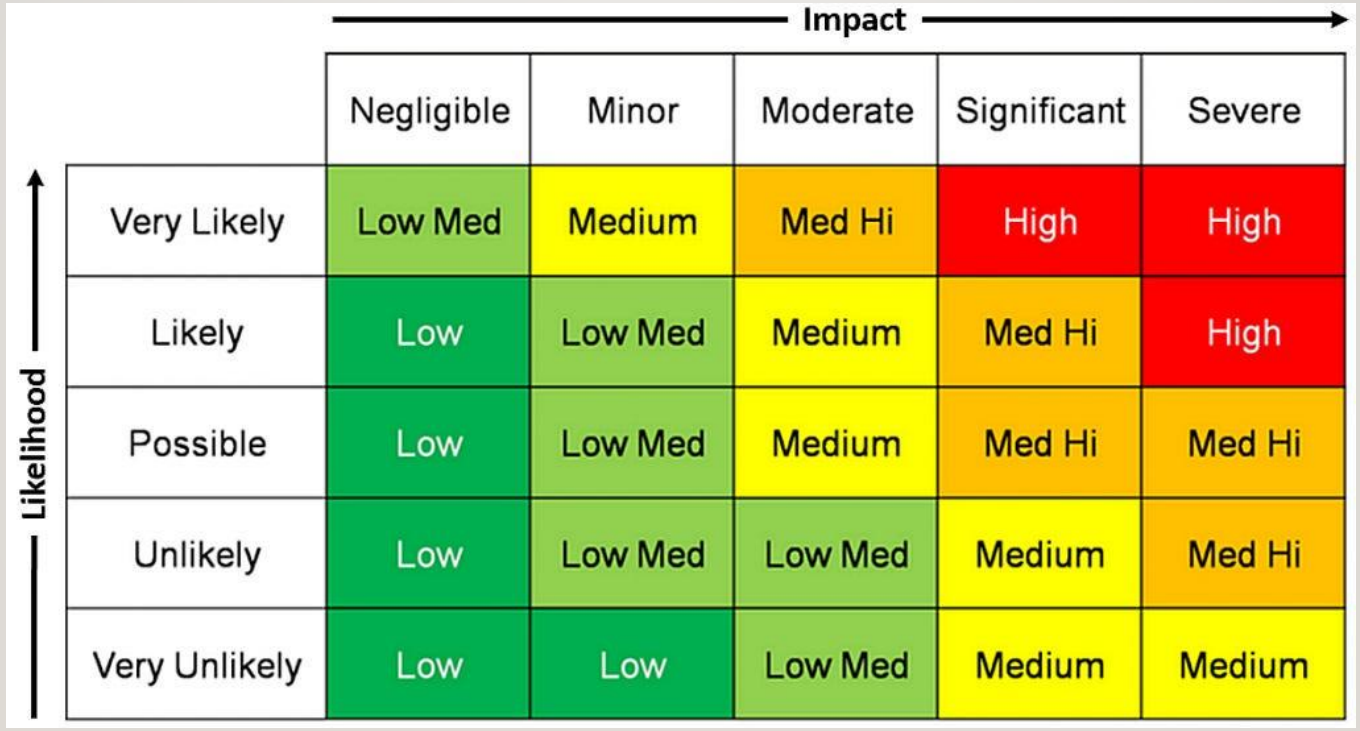
STEPS TAKEN IN ASSESSING RISK IN AN INSTITUTION

3. **Risk Mitigation**: Designing strategies to minimize the identified risks, including technological solutions, policy changes, and procedural updates.
4. **Risk Monitoring**: Continuously monitoring risk factors and adjusting strategies to address emerging threats.

TOOLS AND TECHNIQUES FOR RISK ASSESSMENT

- **Risk Matrix**: A visual tool used to categorize risks based on their likelihood and impact.
- **ISO 31000**: A standard for risk management that provides a structured approach to risk assessment and mitigation.
- **NIST Cybersecurity Framework**: A set of guidelines for managing cybersecurity risk, which can be adapted for institutional security risk assessments.

EXAMPLE OF RISK MATRIX



Likelihood \ Impact	Negligible	Minor	Moderate	Significant	Severe
Very Likely	Low Med	Medium	Med Hi	High	High
Likely	Low	Low Med	Medium	Med Hi	High
Possible	Low	Low Med	Medium	Med Hi	Med Hi
Unlikely	Low	Low Med	Low Med	Medium	Med Hi
Very Unlikely	Low	Low	Low Med	Medium	Medium

INSIDER THREAT

- Insider threats refer to security risks originating from within the institution, often from employees or trusted individuals who misuse their access to data and systems.
  - These employees have authorized access to an organization's networks, systems, or sensitive information and intentionally or unintentionally cause harm.

TYPES OF INSIDER THREATS

- **Malicious Insiders:** Employees or contractors who intentionally harm the organization, such as by stealing data, sabotaging systems, or leaking sensitive information.
- **Negligent Insiders:** Employees who inadvertently expose the organization to risk due to lack of awareness or failure to follow security protocols.
- **Compromised Insiders:** Individuals whose credentials are stolen or misused by external attackers to gain unauthorized access.

MITIGATION STRATEGIES FOR INSIDER THREATS

1. **Access Control and Least Privilege**: Limit user access to only the data and systems necessary for their job functions to reduce exposure to sensitive information.
2. **Monitoring and Logging**: Implement monitoring systems that track user activity and generate alerts for suspicious behaviour. Regularly review logs for anomalies.
3. **Behavioural Analytics**: Use advanced analytics and machine learning to detect patterns of behaviour that may indicate insider threats, such as unusual file access or data transfers.

MITIGATION STRATEGIES FOR INSIDER THREATS…

3. **Employee Training**: Educate employees on the risks of insider threats, including how to spot phishing attempts and handle sensitive data securely.
4. **Data Loss Prevention (DLP) Tools**: Implement tools that can detect and block the unauthorized transfer of sensitive data, whether through email, USB drives, or other channels.

SECURITY AWARENESS TRAINING

- Security awareness training is critical to educating employees about cybersecurity threats and ensuring they understand the institution's policies and procedures for maintaining a secure environment.

IMPORTANCE OF SECURITY AWARENESS TRAINING

- **Human Element in Security**: The majority of security breaches are due to human error, such as falling victim to phishing attacks or using weak passwords. Regular training helps mitigate these risks by improving employees' security awareness.
- **Fostering a Security Culture**: Continuous education promotes a culture where employees recognize their role in maintaining security, ensuring that security is prioritized in all aspects of the organization.

SOME OF THE TOPICS TO CONSIDER IN SECURITY AWARENESS TRAINING

1. **Phishing and Social Engineering**: Teach employees how to recognize and respond to phishing emails, social engineering attacks, and other manipulation tactics that may lead to unauthorized access.

2. **Password Security**: Emphasize the importance of creating strong, unique passwords and utilizing multi-factor authentication (MFA) to secure accounts.

3. **Data Protection and Privacy**: Ensure employees understand the importance of protecting sensitive information and following privacy regulations.

SOME OF THE TOPICS TO CONSIDER IN SECURITY AWARENESS TRAINING…

3. **Incident Reporting**: Train employees on how to report potential security incidents or suspicious activities promptly.
4. **Safe Internet Practices**: Educate employees on how to safely browse the internet, use secure networks, and avoid malware and ransomware threats.
5. **Compliance with Policies**: Ensure employees understand the institution's security policies and their individual responsibilities in adhering to these policies.

C. METHODS OF DELIVERING SECURITY AWARENESS TRAINING

- **Workshops and Seminars**: In-person or virtual sessions that provide in-depth training on specific security topics.
- **Online Courses**: Self-paced e-learning modules that employees can complete at their convenience.
- **Simulated Phishing Exercises**: Regularly test employees with simulated phishing attacks to gauge their readiness and reinforce training.
- **Awareness Campaigns**: Posters, emails, and newsletters to keep security top of mind and update employees on new threats and policies.

9. INTRODUCTION TO RISK MANAGEMENT

- Focuses on the principles, frameworks, and best practices in risk management as they apply to cybersecurity and information systems.
- Will look at key concepts in identifying, assessing, and managing risks, as well as strategies for mitigating threats and ensuring the security of information systems.

RISK MANAGEMENT FRAMEWORK

- A risk management framework provides a structured approach to identifying, assessing, and managing risks.
- It is a key component in protecting an organization’s assets, ensuring business continuity, and maintaining compliance with security and regulatory requirements.

RISK MANAGEMENT FRAMEWORK KEY CONCEPTS

- **Risk Identification**: The process of identifying potential risks that could affect the organization.
  - This includes understanding external and internal threats, vulnerabilities, and the impact on business operations.
- **Risk Assessment**: Involves evaluating the likelihood and impact of each identified risk to prioritize which risks need to be managed first.

RISK MANAGEMENT FRAMEWORK KEY CONCEPTS…

- **Risk Treatment**: The process of deciding how to address each risk, whether it be through mitigation, acceptance, transfer (e.g., insurance), or avoidance.
- **Risk Monitoring and Review**: Continuously monitoring risks and reviewing the effectiveness of risk management strategies.
  - This involves revising risk treatment plans as new risks emerge or conditions change.

COMMON RISK MANAGEMENT FRAMEWORKS:

- **ISO 31000**: A global standard that provides guidelines for risk management, including principles and processes that help organizations manage risk effectively across all aspects of their operations.
- **COBIT (Control Objectives for Information and Related Technology)**: A framework for IT governance and management that focuses on aligning IT processes with business goals and managing risks associated with IT.

COMMON RISK MANAGEMENT FRAMEWORKS:

- **NIST SP 800-53**: A framework developed by the National Institute of Standards and Technology (NIST) for federal agencies in the U.S.
  - It outlines security and privacy controls for federal information systems, and is widely adopted in both government and private sector organizations.

CYBER RISK GOVERNANCE

- Cyber risk governance is the process of managing and overseeing the risks associated with cybersecurity.
- It involves ensuring that appropriate measures are in place to safeguard an organization's digital assets while aligning with the organization's overall strategic objectives.

CYBER RISK GOVERNANCE KEY PRINCIPLES

- **Risk Ownership**: While IT teams are responsible for implementing technical security controls, business leaders must also take ownership of the risk within their areas of responsibility (e.g., finance, operations).

CYBER RISK GOVERNANCE KEY PRINCIPLES

- **Leadership and Oversight**: Top management should play an active role in cyber risk governance.
  - This ensures that security risks are prioritized and the organization's security posture is aligned with business goals.
- **Accountability**: Clearly defining the roles and responsibilities for managing cyber risks within the organization.
  - This includes assigning risk owners and ensuring accountability at all levels.

CYBER RISK GOVERNANCE KEY PRINCIPLES…

- **Integration with Enterprise Risk Management**: Cybersecurity risk management should be integrated into the broader enterprise risk management framework.
  - This allows the organization to assess and manage all risks holistically, without isolating cybersecurity as a separate discipline.
- **Compliance and Regulatory Oversight**: Ensuring that cybersecurity governance practices are in line with relevant laws and regulations

CYBER RISK GOVERNANCE FRAMEWORKS

- **ISO/IEC 27001**: An international standard that outlines requirements for establishing, implementing, operating, monitoring, reviewing, maintaining, and improving an information security management system (ISMS).
- **CIS Critical Security Controls**: A set of cybersecurity best practices and guidelines for organizations to improve their cybersecurity posture and manage risks more effectively.

CYBER RISK GOVERNANCE FRAMEWORKS

- **NIST Cybersecurity Framework (CSF)**: A widely adopted framework that provides a flexible structure for organizations to manage and reduce cybersecurity risks.
  - It includes five core functions: Identify, Protect, Detect, Respond, and Recover.

RISK MITIGATION STRATEGIES

- Risk mitigation refers to the actions taken to reduce or eliminate risks that could negatively impact an organization.
  - Effective risk mitigation strategies involve not only protecting assets but also ensuring that the organization can recover quickly if an incident occurs.

TYPES OF RISK MITIGATION STRATEGIES

1. **Avoidance**: Changing business processes or avoiding certain activities that introduce significant risk.
    - For example, discontinuing the use of outdated or vulnerable technologies that are prone to cyberattacks.
2. **Transference**: Shifting the risk to another party, typically through insurance or outsourcing.
    - For example, organizations may use third-party vendors for cybersecurity services or transfer financial risk through cyber insurance.

TYPES OF RISK MITIGATION STRATEGIES

3. **Mitigation**: Reducing the likelihood or impact of a risk by implementing preventive measures.
    - This can include technical controls such as firewalls, intrusion detection systems, and encryption, as well as organizational measures like training and awareness programs.
4. **Acceptance**: In cases where the cost of mitigating a risk is higher than the potential loss, an organization may choose to accept the risk and its consequences.
    - This is often done when risks are deemed to be low or have minimal impact.

TYPES OF RISK MITIGATION STRATEGIES

5. **Detection and Response**: Ensuring that there are mechanisms in place to detect risks early and respond effectively to minimize damage.
    - This can include setting up incident response teams, security monitoring, and creating detailed response plans.

COMMON RISK MITIGATION TACTICS

- **Layered Security (Defence in Depth)**: Using multiple layers of security controls (e.g., firewalls, intrusion detection systems, and encryption) to protect an organization's IT infrastructure.
- **Regular Security Audits and Assessments**: Conducting regular vulnerability assessments and penetration testing to identify and fix weaknesses before they can be exploited.

COMMON RISK MITIGATION TACTICS…

- **Security Awareness Training**: Educating employees about security best practices and common threats, such as phishing and social engineering, to reduce the risk of human error.
- **Incident Response Planning**: Developing a structured incident response plan to quickly address and recover from security breaches or cyberattacks.

COMMON RISK MITIGATION TACTICS…

- **Business Continuity and Disaster Recovery**: Implementing strategies and procedures to ensure that critical business functions can continue or quickly resume after a security incident or disaster.
  - This includes having backup systems, data recovery processes, and alternative communication methods.